CASE STUDY

# The Year 2006 in Intrusions: A Dated Record

*A TeamStarWolf case study. Published 13 November 2026; every source checked as of that date.*

## Executive summary

The loudest breach of 2006 was a burglary. On 3 May a Department of Veterans Affairs data analyst's home was broken into, and a laptop and external drive he had taken home without authorization were stolen. The drive held names, Social Security numbers and dates of birth for up to 26.5 million veterans and some spouses, and later matching added as many as 1.1 million active-duty members, 430,000 National Guard members and 645,000 Reserve members (Confirmed [20][22][25]). The Secretary was not told until 16 May and the public until 22 May (Confirmed [13][25]). The equipment was recovered on 28 June, and the FBI and VA's Inspector General were highly confident the files had not been compromised (Confirmed [13][25]). The Inspector General still found the notification neither appropriate nor timely (Confirmed [25]). GAO's later list of 2006 federal losses reads the same way: CDs released by a contractor at USDA, a Marine Corps thumb drive, a lost Education Department CD and stolen laptops at CMS and the Transportation Department's Inspector General (Confirmed [13]). The White House created an Identity Theft Task Force on 10 May, and OMB told agencies in June to encrypt mobile devices and in July to report every incident involving personal information to US-CERT within one hour (Confirmed [74][75][76]).

The working attack surface was the Office document and the web page. The year opened with MS06-001 on 5 January, an out-of-cycle fix for the Windows Metafile flaw that was being exploited against fully patched Windows XP SP2 before any patch existed (Confirmed [1][3]). Microsoft bulletins say flaws in Internet Explorer (April), Word (June), Excel (July), PowerPoint (August and October), the Server service (August), Vector Markup Language (September, a second out-of-cycle fix) and the WebViewFolderIcon control (October) were all being exploited when the fixes shipped (Confirmed [18][28][34][35][39][41][43][44]). The SANS Internet Storm Center described the May Word attack as e-mail sent to chosen people in one organization, the work of one group in a very targeted attack (Reported [30]). Only two CVEs with a 2006 id sit in CISA's Known Exploited Vulnerabilities catalog today, and one of them is that Word flaw (Confirmed [32]).

The state record for 2006 was written years later. Mandiant's 2013 report says it saw APT1, which it assesses to be PLA Unit 61398, conducting espionage from 2006 and using its WEBC2 backdoors from July 2006 (Confirmed [61]). A 2018 indictment alleges that the APT10 group's "Technology Theft Campaign" began in or about 2006, and ATT&CK dates menuPass to at least 2006 (Confirmed [66][67]; allegations). McAfee's Operation Shady RAT paper lists eight intrusions it dates to 2006 from one command server's logs, and names no country (Confirmed [68]). In Athens, Greek officials made the Vodafone wiretaps public in February 2006 (Reported [69]).

Inside the companies, TJX's intruder spent 2006 intercepting card authorization requests and was not found until 18 December (Confirmed [54][56]). The FTC settled with ChoicePoint for a $10 million civil penalty, the largest in its history to that date, and with the card processor CardSystems Solutions (Confirmed [10][12]). Hewlett-Packard told the SEC that a third party retained by its outside investigators had in some cases used pretexting to obtain phone records on directors' calls (Confirmed [51]). Botnet herders Jeanson James Ancheta and Christopher Maxwell were sentenced or pleaded guilty, and Maxwell's botnet had disrupted a Seattle hospital (Confirmed [15][26]). NIST issued FIPS 200 and SP 800-53 Revision 1, the IETF published TLS 1.1, MITRE released the first CWE List, and Microsoft shipped Windows Vista Beta 2 with address space layout randomization on by default (Confirmed [77][78][86][88][87]).

This study records the year by date. It is built only from sources opened on 12 and 13 November 2026 and from checks of the library's data run on 12 and 13 November 2026, and is checked as of 13 November 2026.

## Key facts at a glance

| Field | Value |
|---|---|
| Period | 1 January to 31 December 2006, plus the records that open or close a 2006 event: the Windows Metafile disclosure (28 Dec 2005), the 2001 to 2005 conduct behind the year's prosecutions, TJX's 8-K and 10-K (2007), the Gonzalez charges (2008), Mandiant's APT1 report (2013), the PLA and APT10 charges (2014, 2018), McAfee's Shady RAT paper (2011) and the KEV additions (2022) |
| Lost federal data | VA up to 26.5 million veterans plus service members (burglary, 3 May; recovered 28 Jun); USDA about 350,000; Marine Corps 207,570; Education 13,756; CMS 49,572; DOT OIG about 133,000 (Confirmed [13][20][22][25]) |
| Corporate cases | ChoicePoint FTC settlement ($10 million penalty, $5 million redress, 26 Jan); CardSystems settlement (23 Feb); HP pretexting disclosure (6 Sep); TJX intrusion found (18 Dec) (Confirmed [9][10][12][51][54]) |
| Exploited at release | MS06-001 (WMF), MS06-013 (IE), MS06-027 (Word), MS06-037 (Excel), MS06-040 (Server service), MS06-048 and MS06-060 (PowerPoint), MS06-055 (VML), MS06-057 (WebViewFolderIcon) (Confirmed [3][18][28][34][35][39][41][43][44]) |
| Microsoft | MS06-001 (5 Jan) to MS06-078 (12 Dec); two out-of-cycle bulletins, MS06-001 and MS06-055 (Confirmed [3][41][49]; the count of 78 and the out-of-cycle reading are Inferred) |
| CVE volume | 6,659 CVE records with an NVD publication date in 2006; two CVE-2006 ids in KEV (Demonstrated [50]; Confirmed [32]) |
| Malware | Mywife.E (Nyxem) file corruption from 3 Feb; IRCBot.ST spreading through MS06-040 (Aug, Reported); Gpcode file-encrypting trojan (undated, Reported) (Confirmed [6]; Reported [38][8]) |
| State record | APT1 seen from 2006 and WEBC2 from July 2006 (Mandiant); menuPass and the APT10 "Technology Theft Campaign" from about 2006 (alleged); Shady RAT victims from mid-2006 (McAfee); the Athens wiretaps made public (Feb, Reported) (Confirmed [61][66][67][68]; Reported [69][70]) |
| Prosecutions | Benimeli (7 Feb); Maxwell (10 Feb, plea 4 May); Levine (22 Feb, 96 months); Ancheta (8 May, 57 months); McKinnon extradition ordered (4 Jul); Bailey (15 Jun); the Russian bookmaker extortionists (Oct, Reported) (Confirmed [60][14][15][17][26][27][33]; Reported [59]) |
| Law and policy | Cyber Storm I (Feb); FIPS 200 (1 Mar); EU Data Retention Directive (15 Mar); CIPAC (24 Mar); identity-theft executive order (10 May); NIPP (Jun); OMB M-06-16 (23 Jun) and M-06-19 (12 Jul); UK Police and Justice Act (8 Nov); the US e-discovery rules (1 Dec) (Confirmed [16][77][83][72][74][75][76][84][85]) |
| Standards | TLS 1.1 (Apr); SP 800-88 (31 Aug); SP 800-92 (13 Sep); SP 800-100 (31 Oct); SP 800-53 Rev. 1 (19 Dec); the first CWE List; the PCI Security Standards Council (Confirmed [86][80][79][81][78][88][82]) |
| This study's MITRE binding | 20 ATT&CK Enterprise technique rows, all later mappings; no ATT&CK for ICS rows; APT1 (G0006), WEBC2 (S0109), menuPass (G0045) and PoisonIvy (S0012) bound with dating caveats; no campaign object; NVD's CWE-20, CWE-94, CWE-119 and CWE-120 plus study-class CWEs; CAPEC and D3FEND pairings from the library's data; one Enterprise Navigator layer (Part 9) |

## Key findings

- **The year's biggest breach notice followed a burglary, not a hack.** VA says the burglars were not believed to have targeted the data, and the FBI's forensic review found the files had not been compromised. The Inspector General found the notification neither appropriate nor timely, and also faulted the employee's handling of the data and VA's safeguarding policies (Confirmed [25]).
- **Lost media and laptops drove federal policy.** GAO lists six 2006 federal losses from CDs, a thumb drive and laptops, and OMB then called for encryption of mobile devices, two-factor remote access and one-hour reporting (Confirmed [13][75][76]; reading them as a response is Inferred).
- **Office documents became a delivery format for exploits.** Microsoft says Word, Excel and PowerPoint flaws were each exploited before their fixes, in four bulletins from June to October (Confirmed [28][34][39][44]).
- **Microsoft broke its monthly cycle twice.** MS06-001 on 5 January and MS06-055 on 26 September both fixed flaws already being exploited (Confirmed [3][41]; the out-of-cycle reading is Inferred).
- **Few of 2006's flaws carry forward.** NVD has 6,659 records published in 2006, and only two CVE-2006 ids are in KEV (Demonstrated [50]; Confirmed [32]).
- **Later records date their view of long espionage campaigns from 2006.** Mandiant's APT1 visibility, the APT10 indictment's alleged campaign and McAfee's Shady RAT logs all start in 2006, and each source allows that activity may have begun earlier. None of these reports was public in 2006 (Confirmed [61][66][68]; Inferred for the reading).
- **TJX's intruder worked through the year undetected.** The FTC says card authorization requests were intercepted from May to December 2006; TJX found suspicious software on 18 December (Confirmed [56][54]).
- **Botnets were prosecuted as a business with real-world harm.** Ancheta sold botnet access for DDoS and spam and damaged Navy and DISA networks, and Maxwell's botnet disrupted a hospital (Confirmed [26][15]).
- **Pretexting reached a board.** A third party working for HP's outside investigators had in some cases used pretexting to get phone records on directors' calls, and HP's chairman agreed to step down (Confirmed [51][52]).

## Top recommendations

1. **Encrypt anything that leaves the building.** OMB's June memo asked agencies to encrypt mobile devices after the VA loss (Confirmed [75]). A stolen drive with encrypted data is an inventory problem, not a notice to millions (Inferred).
2. **Write the notice chain before you need it.** VA's Secretary heard 13 days after the theft and the public 19 days after, and the Inspector General found the notice neither appropriate nor timely (Confirmed [25]; the intervals are Inferred). M-06-19's one-hour reporting rule is one model (Confirmed [76]).
3. **Have a plan for a flaw with no patch.** The WMF and VML flaws were exploited before their out-of-cycle fixes (Confirmed [1][3][40][41]).
4. **Treat Office files from outside as untrusted code.** Word, Excel and PowerPoint flaws were exploited before patches, and the Word attack came by targeted e-mail (Confirmed [28][34][39]; Reported [30]).

5. **Block what the bulletin tells you to block.** MS06-040's workarounds were to block TCP 139 and 445 at the perimeter and on hosts (Confirmed [35]).
6. **Turn on the memory protections you already own.** Microsoft's own test WMF file was stopped by DEP on NX-capable hardware (Confirmed [87]).
7. **Watch for exfiltration from the card path.** TJX's intruder intercepted authorization requests in transit and staged them in files on the network (Confirmed [56]).
8. **Set blank and default passwords to something real.** Mywife.E spread through blank Administrator passwords and writable shares (Confirmed [6]).
9. **Log, and keep the logs.** NIST's SP 800-92 on log management came out in September (Confirmed [79]); TJX's discovery came seventeen months after first access (Inferred from [54]).
10. **Bound what your investigators may do.** HP's board learned that its own leak inquiry had used pretexting to get phone records (Confirmed [51][53]).

## Scope and method

This study covers intrusions, vulnerabilities, malware, data losses, prosecutions, regulation, standards and policy dated to 2006, plus the later records that open, close or explain a 2006 event. It follows the method of the case studies collection: primary sources first, every claim graded, and numbers given as the source states them. Sources were opened on 12 and 13 November 2026, and the library data checks were run on 12 and 13 November 2026.

| Grade | Meaning in this study |
|---|---|
| Confirmed | The primary record was opened and states the fact: a vendor bulletin or advisory, a CERT/CC note, a US-CERT alert in CISA's archive, a CVE or NVD record, the KEV catalog, a Justice Department release or indictment, a court judgment, an SEC filing, an FTC release or complaint, a GAO report, an agency or Inspector General release, a statute, directive or OMB memorandum, a NIST, IETF, FIRST or MITRE record, a vendor research report stated as that vendor's own finding, a live ATT&CK page, or a library study, only for the fact that it is the home for an event |
| Reported | Only a secondary source supports the fact: The Intercept and IEEE Spectrum on the Athens wiretaps, the SANS Internet Storm Center diary, F-Secure's malware descriptions, and Out-Law on the Russian bookmaker case. The source is named in the text |
| Demonstrated | A check this study ran itself and saw the result: the NVD count, and id, name, tactic and page checks in the library's data files and `mitre/` page tree |
| Inferred | The study's own reading, labelled where it appears. Every ATT&CK, CAPEC and D3FEND id bound to a 2006 event is Inferred as to the binding, and so is every CWE that NVD does not list |

Indictments and complaints are allegations; where this study cites one, the record confirms that the allegation was made, not that it was proven. Company filings are the company's own account, and Mandiant's and McAfee's attributions are those vendors' assessments, not government findings.

Limits a reader should know:

- **CVE existed; ATT&CK, CVSS v2 and KEV did not.** The 2006 bulletins carry CVE ids, and NVD lists a CWE for most of the ones checked here (Confirmed [5][31][37][42][46]). ATT&CK came years later, so no

2006 record carries an ATT&CK id, and every technique in Part 9 is this study's later mapping unless ATT&CK itself dates the object to 2006 (Inferred). FIRST released CVSS v2 on 20 June 2007, so any v2 score on a 2006 record is a retrofit (Confirmed [90]). KEV added its two CVE-2006 entries in 2022 (Confirmed [32]).

- **CWE arrived in 2006; CAPEC's first date is not confirmed here.** MITRE's history page dates the first CWE List and taxonomy to 2006 (Confirmed [88]). CAPEC's archive lists version 1.0 first but gives no date, so this study states no CAPEC release date (Confirmed [89]).
- **What was not checked.** No primary was opened for: the 2006 intrusions at the Commerce Department's Bureau of Industry and Security, the State Department and the Naval War College; AOL's search-data release; the Yamanner Yahoo Mail worm; the Blue Security DDoS; the Moroccan sentence of the Zotob author; the Texas settlement with Sony BMG; the UCLA breach; US-CERT's TA06-024A (Nyxem), TA06-139A (Word) and TA06-220A (MS06-040), whose legacy addresses no longer resolve; Microsoft Security Advisory 919637; the FBI IC3 2006 annual report and APWG's 2006 phishing reports; the Leap.A Mac worm; the NRC notice on Browns Ferry; Symantec Japan's Backdoor.Wualess page; the number of the identity-theft executive order; the month of the PCI Council's founding and the date of PCI DSS 1.1; the checklist items in M-06-16; the FTC's Guidance Software case; and the NVD weakness entry for Sendmail's CVE-2006-0058. They are left out. Their absence here is not evidence that nothing happened.

## Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date. Rows marked "frame" or "boundary" open or close a 2006 event.

| Date | Event | Thread | Sector | Grade | Sources |
|---|---|---|---|---|---|
| 2001-02-01 to 2002-03-19 (frame) | Gary McKinnon allegedly accesses 97 US Government computers (extradition ordered 4 Jul 2006) | Crime | Government, defense | Confirmed (as alleged) | [27] |
| 2003-01 to 2003-07 (frame) | Scott Levine of Snipermail steals more than one billion records from Acxiom (sentenced 22 Feb 2006) | Crime | Data services | Confirmed | [17] |
| 2004-01-23 (frame) | First WEBC2-KT3 compile time, per Mandiant | Espionage | Unknown | Confirmed | [61] |
| 2005-01 (frame) | Maxwell's botnet disrupts Northwest Hospital in Seattle | Crime | Healthcare | Confirmed | [14][15] |
| 2005-01 to 2005-05 (frame) | William Bailey Jr. allegedly downloads records on more than 80,000 American College of Physicians members | Crime | Professional associations | Confirmed (as alleged) | [33] |
| 2005-07 (frame) | TJX's intruder first gets in. Home: E-Commerce Threats | Intrusion | Retail | Confirmed | [54][91] |

| Date | Event | Thread | Sector | Grade | Sources |
|---|---|---|---|---|---|
| 2005-12-28 (frame) | Windows Metafile flaw exploited before a patch: VU#181038, Advisory 912840, CVE-2005-4560. Home for the 2005 disclosure: The Year 2005 in Intrusions | Exploitation | Cross-sector | Confirmed | [1][2][5][92] |
| 2006-01 | DOE, DHS S&T and Natural Resources Canada publish the Roadmap to Secure Control Systems in the Energy Sector | Policy | Energy | Inferred (month) | [73] |
| 2006-01 | Ancheta pleads guilty (C.D. Cal.) | Crime | Government, consumers | Confirmed | [26] |
| 2006-01-02 to 2006-01-23 | Richard Benimeli allegedly disables a former client's computer system and sends extortion threats | Crime | Unknown | Confirmed (as alleged) | [60] |
| 2006-01-05 | MS06-001 fixes the WMF flaw out of cycle; US-CERT alert | Vulnerability | Cross-sector | Confirmed | [3][4] |
| 2006-01-19 | USDA FSA contractor releases CDs with SSNs and tax ids of about 350,000 tobacco program participants | Data loss | Government, agriculture | Confirmed | [13] |
| 2006-01-23 | A CNET story on a January HP board meeting restarts HP's leak inquiry (Kona II) | Insider | Technology | Confirmed | [53] |
| 2006-01-26 | FTC announces the ChoicePoint settlement: $10 million civil penalty, $5 million redress | Regulation | Data broker | Confirmed | [10][9] |
| 2006-01-30 | Microsoft Advisory 904420 on Win32/Mywife.E@mm (Nyxem) | Malware | Cross-sector | Confirmed | [6] |
| 2006-02 | Cyber Storm I, the first DHS-sponsored cyber exercise across the private sector and governments | Policy | Cross-sector | Confirmed | [16] |
| 2006-02 | Greek officials disclose the Vodafone wiretaps at a press conference; the Vodafone CEO gives a newspaper interview | Espionage | Telecommunications, government | Reported | [69][70] |
| 2006-02-03 | Mywife.E's first scheduled file corruption | Malware | Cross-sector | Confirmed | [6] |
| 2006-02-07 | Benimeli indicted (N.D. Ohio) | Crime | Unknown | Confirmed | [60] |
| 2006-02-10 | Christopher Maxwell indicted (W.D. Wash.) | Crime | Healthcare, government | Confirmed (as alleged) | [14] |

| Date | Event | Thread | Sector | Grade | Sources |
|---|---|---|---|---|---|
| 2006-02-17 | USDA mails notices for the January release | Data loss | Government | Confirmed | [13] |
| 2006-02-22 | Levine sentenced to 96 months | Crime | Data services | Confirmed | [17] |
| 2006-02-23 | FTC settles with CardSystems Solutions and Solidus Networks | Regulation | Payment processing | Confirmed | [12] |
| 2006-03 | HP's draft Kona II report describes techniques including pretexting | Insider | Technology | Confirmed | [53] |
| 2006-03-01 | NIST FIPS 200 final | Standards | Government | Confirmed | [77] |
| 2006-03-14 | Marine Corps loses a thumb drive with PII on 207,570 enlisted Marines (notice 24 Mar) | Data loss | Government, defense | Confirmed | [13] |
| 2006-03-15 | EU Data Retention Directive 2006/24/EC | Law | Telecommunications | Confirmed | [83] |
| 2006-03-22 | CERT/CC VU#834865, Sendmail signal race (CVE-2006-0058) | Vulnerability | Internet | Confirmed | [47] |
| 2006-03-24 | Federal Register notice establishes CIPAC | Policy | Critical infrastructure | Confirmed | [72] |
| 2006-04 | RFC 4346, TLS 1.1 | Standards | Internet | Confirmed | [86] |
| 2006-04-06 | Vodafone Greece and Ericsson Hellas chiefs before the Greek parliamentary committee | Espionage | Telecommunications | Reported | [69][70] |
| 2006-04-11 | MS06-013 (IE, CVE-2006-1359 exploited); MS06-014 (MDAC, CVE-2006-0003, privately reported) | Vulnerability | Cross-sector | Confirmed | [18][45] |
| 2006-04-27 | US-CERT: scripts in eBay postings may enable phishing | Vulnerability | E-commerce | Confirmed | [19] |
| 2006-05-03 | VA analyst's home burglarized; laptop and drive stolen | Data loss | Government, veterans | Confirmed | [13][25] |
| 2006-05-04 | Maxwell pleads guilty | Crime | Healthcare, defense | Confirmed | [15] |
| 2006-05-08 | Ancheta sentenced to 57 months | Crime | Government, consumers | Confirmed | [26] |
| 2006-05-10 | Identity-theft executive order; a District Judge sends McKinnon's case to the Home Secretary | Policy; Crime | Government | Confirmed | [74][27] |

| Date | Event | Thread | Sector | Grade | Sources |
|---|---|---|---|---|---|
| 2006-05-16 | VA Secretary told of the theft | Data loss | Government | Confirmed | [13][25] |
| 2006-05-18 and 2006-05-24 | HP board receives the Kona II results; final report | Insider | Technology | Confirmed | [53] |
| 2006-05-19 | Word zero-day: VU#446012 and a US-CERT alert; ISC first reports the attack | Exploitation | Cross-sector | Confirmed | [29][100][31] |
| 2006-05-21 | ISC diary 1345: targeted Word attachments to people in one organization | Exploitation | Unknown | Reported | [30] |
| 2006-05-22 | VA announces the theft publicly | Data loss | Government, veterans | Confirmed | [20] |
| 2006-05-26 | Microsoft blog: Vista Beta 2 has ASLR on by default | Standards | Technology | Confirmed | [87] |
| 2006-06 | First National Infrastructure Protection Plan; Greek Supreme Court prosecutor links the tapping to the Vodafone engineer's death (statement) | Policy; Espionage | Critical infrastructure; telecommunications | Confirmed; Reported | [72][69] |
| 2006-06-03 and 2006-06-06 | VA updates: active-duty, Guard and Reserve members in the data | Data loss | Government, defense | Confirmed | [21][22] |
| 2006-06-09 | VA begins mailing letters | Data loss | Government | Confirmed | [13] |
| 2006-06-13 | MS06-027 fixes the exploited Word flaw (CVE-2006-2492) | Vulnerability | Cross-sector | Confirmed | [28] |
| 2006-06-15 | Bailey indicted | Crime | Professional associations | Confirmed (as alleged) | [33] |
| 2006-06-19 | Education Department contractor CD with 13,756 records lost in transit (notices 2 Oct) | Data loss | Government, education | Confirmed | [13] |
| 2006-06-20 | GAO-06-897T testimony on VA | Policy | Government | Confirmed | [24] |
| 2006-06-21 | VA offers a year of free credit monitoring | Data loss | Government | Confirmed | [23] |
| 2006-06-22 | CMS contractor laptop theft, 49,572 Medicare beneficiaries | Data loss | Government, healthcare | Confirmed | [13] |
| 2006-06-23 | OMB M-06-16, Protection of Sensitive Agency Information | Policy | Government | Confirmed | [75] |
| 2006-06-28 | VA laptop and drive recovered intact | Data loss | Government | Confirmed | [25] |

| Date | Event | Thread | Sector | Grade | Sources |
|---|---|---|---|---|---|
| 2006-07 | Mandiant first observes APT1 using WEBC2 backdoors; Shady RAT victims logged (four in July) | Espionage | Construction, steel, research, trade | Confirmed | [61][68] |
| 2006-07-04 | Home Secretary orders McKinnon's extradition | Crime | Government | Confirmed | [27] |
| 2006-07-11 | MS06-037 (Excel, exploited); VA OIG review issued | Vulnerability; Data loss | Cross-sector; government | Confirmed | [34][25] |
| 2006-07-12 | OMB M-06-19: report PII incidents to US-CERT within one hour | Policy | Government | Confirmed | [76] |
| 2006-07-27 | DOT OIG laptop stolen from a parked car, about 133,000 people | Data loss | Government | Confirmed | [13] |
| 2006-08 | Browns Ferry Unit 3 manual shutdown after control-network traffic overload (GAO does not call it an attack) | Industrial | Energy (nuclear) | Confirmed | [71] |
| 2006-08-08 | MS06-040 (Server service) and MS06-048 (PowerPoint), both exploited; VU#650769 | Vulnerability | Cross-sector | Confirmed | [35][39][36] |
| 2006-08-13 | F-Secure points to IRCBot.ST, the first variant of its family to spread with the MS06-040 exploit | Worm | Cross-sector | Reported | [38] |
| 2006-08-31 | NIST SP 800-88, media sanitization | Standards | Government | Confirmed | [80] |
| 2006-09 | Shady RAT logs a US international trade organization | Espionage | Trade | Confirmed | [68] |
| 2006-09-06 | HP 8-K: director Keyworth a leak source; pretexting used to get phone records | Insider | Technology | Confirmed | [51] |
| 2006-09-12 | HP 8-K: Dunn to step down as chairman, Keyworth resigns; MS06-040 re-released as v2.0 | Insider; Vulnerability | Technology; cross-sector | Confirmed | [52][35] |
| 2006-09-13 | NIST SP 800-92, log management | Standards | Government | Confirmed | [79] |
| 2006-09-19 | VML zero-day: Advisory 925568 and a US-CERT alert | Exploitation | Cross-sector | Confirmed | [41][40] |
| 2006-09-22 | CERT/CC VU#867796, Apple AirPort driver overflows (CVE-2006-3507) | Vulnerability | Technology | Confirmed | [48] |
| 2006-09-26 | MS06-055 fixes the VML flaw out of cycle | Vulnerability | Cross-sector | Confirmed | [41] |

| Date | Event | Thread | Sector | Grade | Sources |
|---|---|---|---|---|---|
| 2006-09-27 | HP 8-K on the Kona II timeline | Insider | Technology | Confirmed | [53] |
| 2006-10 | Shady RAT logs the ASEAN Secretariat (10 months); a foreign hacker plants malware at a Harrisburg water filtering plant | Espionage; Industrial | Government; water | Confirmed | [68][71] |
| About 2006-10-03 | Three Russians sentenced to eight years for DDoS extortion of UK bookmakers. Home: Four Books on Cybercrime | Crime | Gambling | Reported | [59][92] |
| 2006-10-10 | MS06-057 (WebViewFolderIcon) and MS06-060 (PowerPoint), both exploited | Vulnerability | Cross-sector | Confirmed | [43][44] |
| 2006-10-14 | Max Butler allegedly sells card data to a buyer in W.D. Pa. (again 6 Dec). Home: Four Books on Cybercrime | Crime | Payments | Confirmed (as alleged) | [58][92] |
| 2006-10-31 | NIST SP 800-100 | Standards | Government | Confirmed | [81] |
| 2006-11 | Shady RAT logs a US real-estate firm | Espionage | Real estate | Confirmed | [68] |
| 2006-11-08 | UK Police and Justice Act 2006 receives Royal Assent | Law | Cross-sector | Confirmed | [84] |
| 2006-12 | Vodafone Greece fined 76 million (Reported; currency and regulator not stated) | Espionage | Telecommunications | Reported | [70] |
| 2006-12-01 | US e-discovery amendments to the Federal Rules of Civil Procedure take effect | Law | Cross-sector | Confirmed | [85] |
| 2006-12-06 | FTC launches the ChoicePoint redress program | Regulation | Data broker | Confirmed | [11] |
| 2006-12-12 | MS06-078, the year's last Microsoft bulletin | Vulnerability | Technology | Confirmed | [49] |
| 2006-12-18 to 2006-12-27 | TJX finds suspicious software, confirms an intruder, briefs law enforcement and the card brands, and finds customer data stolen | Intrusion | Retail | Confirmed | [54] |
| 2006-12-19 | NIST SP 800-53 Revision 1 | Standards | Government | Confirmed | [78] |
| 2006 | First CWE List; PCI Security Standards Council founded; Mandiant's APT1 visibility begins; the APT10 "Technology Theft Campaign" begins (alleged); Symantec Japan's Backdoor.Wualess writeup | Standards; Industry; Espionage | Cross-sector | Confirmed; Confirmed per Mandiant [61] for the Wualess writeup, its date Inferred | [88][82][61][66] |

| Date | Event | Thread | Sector | Grade | Sources |
|---|---|---|---|---|---|
| 2007-01-17 (boundary) | TJX announces the intrusion | Intrusion | Retail | Confirmed | [55] |
| 2007-06-20 (boundary) | FIRST releases CVSS v2 | Standards | Cross-sector | Confirmed | [90] |
| 2008-08-05 (boundary) | DOJ charges Albert Gonzalez and ten others, including over TJX. Home: E-Commerce Threats | Crime | Retail | Confirmed (as alleged) | [57][91] |
| 2011-08 (boundary) | McAfee publishes Operation Shady RAT | Espionage | Cross-sector | Confirmed | [68] |
| 2013-02 (boundary) | Mandiant publishes its APT1 report | Espionage | Cross-sector | Confirmed | [61] |
| 2014-05-19 (boundary) | DOJ charges five PLA Unit 61398 officers over 2006 to 2014 intrusions | Espionage | Energy, metals, manufacturing, labor | Confirmed (as alleged) | [62] |
| 2018-12-20 (boundary) | DOJ unseals charges against two APT10 members, conduct from about 2006 | Espionage | Aviation, space, pharmaceutical, energy, maritime | Confirmed (as alleged) | [65][66] |
| 2022-01-21 and 2022-06-08 (boundary) | KEV adds CVE-2006-1547 (Apache Struts 1) and CVE-2006-2492 (Word) | Vulnerability | Cross-sector | Confirmed | [32] |

# Part 2: the data the government lost

## The VA theft

VA's 22 May statement says a data analyst had taken data home without authorization and that it was stolen when his home was burglarized. The data held names, Social Security numbers and dates of birth for up to 26.5 million veterans and some spouses, with no health or financial records, and authorities believed the burglars had not targeted the data (Confirmed [20]). On 3 June VA said some active-duty, Guard and Reserve personnel could be included, estimating 10,000 to 20,000 Guard and Reserve members and 25,000 to 30,000 Navy personnel (Confirmed [21]). After matching with the Department of Defense, the 6 June update raised that to as many as 1.1 million active-duty members, 430,000 National Guard members and 645,000 Reserve members (Confirmed [22]). On 21 June VA offered a year of free credit monitoring and named its Office of Policy and Planning as where the breach happened (Confirmed [23]).

GAO-07-657 gives the internal timeline. The theft was on 3 May and the deputy assistant secretary was told that day, the Chief of Staff on 9 May and the Secretary on 16 May. VA announced on 22 May and began mailing letters on 9 June (Confirmed [13]). VA's Inspector General says the laptop and external drive were recovered intact on 28 June and that the FBI and the OIG were highly confident, from a forensic examination, that the files had not been compromised after the burglary (Confirmed [25]). Its review of 11 July found that the notification was neither appropriate nor timely (Confirmed [25]). GAO testified on 20 June under the title "Information Security: Leadership Needed to Address Weaknesses and Privacy Issues at Veterans Affairs" (Confirmed [24]).

### Five more federal losses

GAO-07-657 records the others (Confirmed [13]):

- **USDA (19 January).** A Farm Service Agency FOIA contractor released CDs carrying the Social Security numbers and tax ids of about 350,000 tobacco program participants. A FOIA official told the contractor not to notify management, and USDA mailed notices on 17 February.
- **Marine Corps (14 March).** A thumb drive with personal information on 207,570 enlisted Marines was lost; an electronic notice went out on 24 March.
- **Education Department (19 June).** A contractor's CD with 13,756 records was lost in transit; notices went out on 2 October.
- **CMS (22 June).** A contractor's laptop was stolen, affecting 49,572 Medicare beneficiaries.
- **DOT Inspector General (27 July).** A laptop with data on about 133,000 people was stolen from a parked car.

None of these was a network intrusion; each was a release, loss or theft of media (Inferred [13]).

### The policy answer

On 10 May the President signed the executive order "Strengthening Federal Efforts to Protect Against Identity Theft", creating the Identity Theft Task Force and asking for a strategic plan within 180 days. The page opened does not show the order's number (Confirmed [74]). OMB's M-06-16 of 23 June recommended four controls within 45 days: encrypt mobile devices, require two-factor authentication for remote access, time out remote sessions after 30 minutes of inactivity, and log data extracts and erase them within 90 days (Confirmed [75]). M-06-19 of 12 July required agencies to report every incident involving personally identifiable information to US-CERT within one hour of discovery, without separating suspected from confirmed breaches (Confirmed [76]). The VA timeline, the GAO list and the OMB memos together read as cause and response (Inferred [13][75][76]).

## Part 3: the vulnerability record

### The Windows Metafile flaw

CERT/CC's VU#181038 (first released 28 December 2005, revised 20 January 2006) says exploit code for the WMF SETABORTPROC flaw had been posted publicly and used against fully patched Windows XP SP2 systems (Confirmed [1]). Microsoft published Security Advisory 912840 on 28 December 2005 and updated it when the fix shipped (Confirmed [2]). MS06-001 (Critical, KB 912919) came on Thursday 5 January 2006 and fixes CVE-2005-4560. Microsoft says the flaw was being exploited at release, lists a malicious web page, an e-mail attachment and WMF embedded in Word documents as vectors, and says blocking the .wmf extension does not protect (Confirmed [3]). The regular release that month was 10 January, which makes MS06-001 an out-of-cycle fix, though the bulletin does not use that term (Inferred [3]). US-CERT issued an alert the same day (Confirmed [4]). NVD lists CWE-20 for CVE-2005-4560, says the flaw was found in the wild, and records no KEV date (Confirmed [5]). The 2005 chronicle is the home for the zero-day's disclosure and its exploitation before the patch (Confirmed [92]).

## Internet Explorer and MDAC in April

MS06-013 (Critical, KB 912812, 11 April) is a cumulative Internet Explorer update covering ten CVEs. One of them, CVE-2006-1359 (createTextRange, CWE-94 in NVD), was being exploited at release (Confirmed [18]). MS06-014 (Critical, KB 911562) the same day fixed the MDAC RDS.Dataspace ActiveX flaw CVE-2006-0003, which was reported privately and was not public at release (Confirmed [45]). NVD lists that CVE as NVD-CWE-noinfo (Confirmed [46]).

## The Office year

- **Word (May and June).** CERT/CC released VU#446012 on 19 May and US-CERT issued an alert the same day (Confirmed [29][100]). NVD records that ISC first reported the zero-day attack on 19 May and lists CWE-120 for CVE-2006-2492 (Confirmed [31]). ISC's diary of 21 May describes e-mail sent to specific people in one organization, each with a Word attachment that exploited the unknown flaw and dropped more code, and judges it the work of one group in a very targeted attack (Reported [30]). MS06-027 (Critical, KB 917336) fixed it on 13 June; Microsoft says it was being exploited at release, and the attack needs the user to open a crafted document (Confirmed [28]). CISA added it to KEV on 8 June 2022 as "Microsoft Word Malformed Object Pointer Vulnerability" (Confirmed [31][32]).
- **Excel (July).** MS06-037 (Critical, KB 917285, 11 July) covers eight CVEs, and Microsoft says two of them, CVE-2006-1301 and CVE-2006-3059, were being exploited at release (Confirmed [34]).
- **PowerPoint (August and October).** MS06-048 (Critical, KB 922968, 8 August) fixed CVE-2006-3590, exploited at release; NVD names Trojan.PPDropper.B as the malware using it (Confirmed [39][101]). MS06-060 (10 October) fixed CVE-2006-4534, also exploited at release (Confirmed [44]).

## The Server service and IRCBot

MS06-040 (Critical, KB 921883, 8 August) fixed CVE-2006-3439 in the Server service. It was privately reported and was being exploited at release, and Microsoft re-released it as version 2.0 on 12 September (Confirmed [35]). The workarounds were to block TCP 139 and 445 at the firewall, use the host firewall and filter with IPsec (Confirmed [35]). CERT/CC's VU#650769 describes a stack buffer overflow that lets a remote attacker without credentials run code as SYSTEM (Confirmed [36]). NVD lists NVD-CWE-Other and no KEV date (Confirmed [37]). F-Secure says IRCBot.ST, also called Mocbot, is the first variant of its IRC backdoor-worm family to spread with the MS06-040 exploit and can run DDoS attacks; its Mocbot.A page points to IRCBot.ST as of 13 August 2006 (Reported [38]). F-Secure's date for IRCBot.ST falls five days after the bulletin; that it marks the start of spreading is this study's reading, not F-Secure's statement (Inferred).

## Vector Markup Language and WebViewFolderIcon

Microsoft published Security Advisory 925568 on VML on 19 September, and US-CERT's alert that day says the flaw was being exploited; the alert was revised on 26 September (Confirmed [40][41]). MS06-055 (Critical, KB 925486) followed on 26 September, outside the 12 September monthly release, for CVE-2006-4868, exploited at release (Confirmed [41]; the out-of-cycle point is Inferred from the dates). NVD describes it as a stack-based buffer overflow in vgx.dll as used by Internet Explorer 6 and Outlook and lists CWE-119 (Confirmed [42]). On 10 October MS06-057 (Critical, KB 923191) fixed CVE-2006-3730 in the WebViewFolderIcon ActiveX control, which had been reported publicly and was being exploited at release; NVD lists CWE-94 (Confirmed [43]).

### Outside Microsoft

- **Sendmail (22 March).** VU#834865 describes a signal I/O race condition, CVE-2006-0058, allowing remote unauthenticated code execution, fixed in Sendmail 8.13.6 (Confirmed [47]).
- **eBay (27 April).** US-CERT warned that scripts in eBay postings could let an attacker steal eBay customers' personal information and so enable phishing (Confirmed [19]).
- **Apple AirPort (22 September).** VU#867796 covers buffer overflows in the AirPort wireless driver, CVE-2006-3507, affecting Mac OS X 10.3.9 and 10.4.7 (Confirmed [48]).

### The count

Microsoft's 2006 bulletins ran from MS06-001 on 5 January to MS06-078 on 12 December; MS06-079 has no page (Confirmed [3][49]). That makes 78 bulletins (Inferred). Of the bulletins opened here, nine say a flaw was being exploited at release: MS06-001, 013, 027, 037, 040, 048, 055, 057 and 060 (Confirmed [3][18][28][34][35][39][41][43][44]; the count is of bulletins opened, not of all 78). Two of the nine, MS06-001 and MS06-055, were out of cycle (Inferred [3][41]). The NVD API returns 6,659 CVE records with an NVD publication date in calendar 2006, by quarter 1,381, 1,811, 1,627 and 1,840; a second split into four date windows gives the same total (Confirmed [50]; Demonstrated). KEV's version of 10 November 2026 holds 1,779 entries and only two CVE-2006 ids: CVE-2006-2492 (Word, added 8 June 2022) and CVE-2006-1547 (Apache Struts 1 ActionForm denial of service, added 21 January 2022) (Confirmed [32]).

## Part 4: malware, botnets and the web

### Mywife.E (Nyxem)

Microsoft's Advisory 904420 of 30 January warned of the Win32/Mywife.E@mm mass mailer, also tracked as CME-24 and Nyxem. It corrupts common document files on the third day of each month, starting 3 February 2006, disables security software, spreads over writable network shares and machines with blank Administrator passwords, and exploits no vulnerability (Confirmed [6]). F-Secure describes Nyxem.E (aliases W32.Blackmal.E@mm, Kama Sutra, MyWife.d) the same way, though its summary says the variant was found in September 2004, which conflicts with the 2006 dating (Reported [7]). Advisory 904420 gives no count of infected machines (Confirmed [6]).

### Gpcode

F-Secure describes Gpcode as a trojan that encrypts files on local and remote drives and asks the user to buy a decoder, and calls it a form of ransomware. Its page carries no date, so this study does not place Gpcode on the timeline or in the layer (Reported [8]). The ransomware ecosystem study covers the later history of the model.

## Ancheta and Maxwell

DOJ sentenced Jeanson James Ancheta in Los Angeles on 8 May to 57 months and called it the first prosecution of its kind. He had pleaded guilty in January to conspiracy under the Computer Fraud and Abuse Act and CAN-SPAM, damaging national-defense computers, and fraud. He earned about $3,000 from more than 30 sales of botnet access used for DDoS and spam, and more than $107,000 in adware commissions from more than 400,000 infected computers. He owes restitution to the Naval Air Warfare Center at China Lake and to DISA (Confirmed [26]). The 2005 chronicle is the home for his arrest of 3 November 2005 (Confirmed [92]).

Christopher Maxwell was indicted in Seattle on 10 February for a botnet built to collect adware commissions. It used compromised servers at California State University Northridge, the University of Michigan and UCLA, earned about $100,000 in fraudulent commissions, and in January 2005 disrupted Northwest Hospital's computers (Confirmed [14]; allegations). He pleaded guilty on 4 May. The plea release says the botnet's scanning disrupted the hospital's operating room doors, pagers and intensive care computers, and that it did more than $135,000 of damage to military computers in the United States and overseas. The same release says more than 400 Defense Department computers in Germany and Colorado cost $138,000 to repair, and puts restitution at more than $252,000 (Confirmed [15]). The healthcare threat watchlist follows attacks on hospitals into later years (Inferred).

## Other prosecutions

- **Benimeli (7 February).** Former contractor Richard Benimeli was indicted in the Northern District of Ohio for remotely disabling a former client's computer system between 2 and 23 January 2006 and sending extortion threats. The DOJ archive serves this release under a file name for a different case (Confirmed [60]; allegations).
- **Levine (22 February).** Scott Levine of Snipermail was sentenced to 96 months for stealing more than one billion records from Acxiom between about January and July 2003. A jury had convicted him on 12 August 2005 on 120 counts of unauthorized access plus access-device fraud and obstruction (Confirmed [17]).
- **McKinnon (10 May and 4 July).** The House of Lords judgment of 2008 records that a District Judge sent Gary McKinnon's case to the Secretary of State on 10 May 2006, who ordered extradition on 4 July. He was alleged to have accessed 97 US Government computers between 1 February 2001 and 19 March 2002 (Confirmed [27]).
- **Bailey (15 June).** William Bailey Jr. was indicted for unauthorized access to the American College of Physicians membership database and downloading records on more than 80,000 members between January and May 2005 (Confirmed [33]; allegations).
- **Russian bookmaker extortion (October).** Out-Law reported on 5 October that Maksakov, Petrov and Stepanov were sentenced in Balakovo to eight years each for DDoS extortion of UK bookmakers, with 54 attacks in 30 countries alleged (Reported [59]). Four Books on Cybercrime is the home (Confirmed [92]).
- **Max Butler (October and December).** The 2007 indictment of Max Ray Butler ("Iceman") alleges card-data sales to a buyer in the Western District of Pennsylvania on or about 14 October and 6 December 2006, in a scheme running from about June 2005 (Confirmed [58]; allegations). Four Books on Cybercrime is the home (Confirmed [92]).

# Part 5: the corporate record

## TJX (summary)

TJX's 10-K says it learned of suspicious software on 18 December 2006 and engaged General Dynamics and IBM on 19 December. On 21 December investigators found strong reason to believe an intruder was still on the systems, and law enforcement was briefed on 22 December; the Secret Service asked TJX to keep the matter confidential. Banks and card processors were told on 26 and 27 December, and on 27 December TJX first found that customer data had been stolen. The intruder had access in July 2005, on later 2005 dates and from mid-May 2006 to mid-January 2007, through the Framingham and Watford systems, took about 100 files from the Framingham system in 2006, and stole no customer data after 18 December (Confirmed [54]). TJX announced the intrusion on 17 January 2007 (Confirmed [55]). The FTC's complaint says that between May and December 2006 the intruder periodically intercepted payment card authorization requests in transit from in-store networks to TJX's central network, stored the data in files on the network and sent the files over the internet to remote computers, after 2005 access through an unauthorized wireless connection to in-store networks (Confirmed [56]; allegations). DOJ charged Albert Gonzalez and ten others on 5 August 2008 with hacking nine US retailers, TJX among them, by wardriving and sniffers, and with taking more than 40 million card numbers (Confirmed [57]; allegations). E-Commerce Threats is the home for TJX and the Gonzalez case (Confirmed [91]).

## The FTC's data-security settlements

- **ChoicePoint (26 January).** The FTC announced $10 million in civil penalties, the largest in its history, and $5 million in consumer redress. It said the financial records of more than 163,000 consumers were compromised, leading to at least 800 identity-theft cases, and brought counts under the Fair Credit Reporting Act and the FTC Act (Confirmed [10]). ChoicePoint's 8-K of 30 January adds biennial independent security assessments for 20 years and no admission of liability (Confirmed [9]). The FTC began the redress program on 6 December, mailing claim forms to more than 1,400 people with a 4 February 2007 postmark deadline (Confirmed [11]). The 2005 chronicle is the home for the ChoicePoint breach itself and also records this settlement (Confirmed [92]).
- **CardSystems (23 February).** The FTC settled with CardSystems Solutions and its successor Solidus Networks (Pay By Touch), calling the breach the largest known compromise of financial data to that date. The alleged failures included not assessing the network's exposure to known attacks such as SQL injection. The order requires a security program with independent audits every two years for 20 years (Confirmed [12]). The 2005 chronicle is the home for the CardSystems breach itself and also records this settlement (Confirmed [92]).

### Hewlett-Packard and pretexting

HP's 8-K of 27 September says its second leak investigation, Kona II, resumed after a 23 January 2006 CNET story reported on a January board meeting. A March draft report described techniques including pretexting; the results went to the 18 May board meeting and the final report followed on 24 May (Confirmed [53]). The 8-K filed 6 September (event date 31 August) disclosed that the inquiry had found director Keyworth was a source of leaks and that a third party retained by HP's outside investigation firm had in some cases used pretexting to get phone records (Confirmed [51]). The committee's counsel said pretexting was not then generally unlawful except with respect to financial institutions (Confirmed [51]). The 8-K of 12 September said Patricia Dunn would step down as chairman at the January 2007 board meeting and that Keyworth had resigned as a director (Confirmed [52]).

### Payment card standards

American Express, Discover, JCB International, MasterCard and Visa founded the PCI Security Standards Council in 2006 (Confirmed [82]). The library's e-commerce study dates the founding to September 2006; that month was not reopened here (Reported [91]).

## Part 6: the state record

### APT1

Mandiant's APT1 report of February 2013 says APT1 has conducted cyber espionage since at least 2006 and that since 2006 Mandiant has seen it compromise 141 companies across 20 major industries. 2006 marks the start of Mandiant's visibility, not necessarily of the activity (Confirmed [61]). Mandiant assesses, as its own finding and not a government one, that APT1 is the 2nd Bureau of the PLA General Staff Department's 3rd Department, Unit 61398. It traced activity to Shanghai networks serving the Pudong New Area and shows the unit's Datong road site as it stood around 2006, before its Center Building went up (Confirmed [61]). It directly observed APT1 using WEBC2 backdoors as early as July 2006, and the first WEBC2-KT3 compile time is 23 January 2004 (Confirmed [61]). It names a 2006 Symantec Japan writeup on Backdoor.Wualess as the earliest public report on APT1 infrastructure; that writeup names the hostname sb.hugesoft.org, registered to the persona UglyGorilla. The Symantec page itself was not opened, and its October 2006 date is inferred from the document id (Confirmed [61]; Inferred for the month). Mandiant calls spear phishing, with a malicious attachment or a link to a malicious file, often a ZIP, APT1's most common way in, and puts average access at 356 days and the longest at 1,764 days; that tradecraft covers 2006 to 2013, not 2006 alone (Confirmed [61]).

On 19 May 2014 DOJ charged five officers of PLA Unit 61398 with 31 counts over intrusions against Westinghouse, SolarWorld, US Steel, ATI, the United Steelworkers and Alcoa, and gave the period as 2006 to 2014 (Confirmed [62]; allegations; read from a Wayback capture because justice.gov showed a bot challenge). ATT&CK's APT1 (G0006) attributes the group to the same unit, gives no start year, and lists 23 Enterprise techniques and software including WEBC2 (S0109) and PoisonIvy (S0012) (Confirmed [63]). ATT&CK's WEBC2 page says the backdoor was used by APT1 as early as July 2006 (Confirmed [64]). The China-attributed actors study is the home for APT1, and The Hacker and the State covers APT1 from 2006 to 2013 (Confirmed [92]).

### menuPass and the APT10 indictment

DOJ unsealed charges on 20 December 2018 against Zhu Hua and Zhang Shilong of the APT10 group, who it says worked for Huaying Haitai and acted with the Ministry of State Security's Tianjin State Security Bureau, with conduct from at least in or about 2006 to 2018 (Confirmed [65]; allegations; read from a Wayback capture). The indictment alleges a "Technology Theft Campaign" beginning in or about 2006 against commercial and defense technology companies and US Government agencies. It reached more than 45 entities in at least 12 states and took hundreds of gigabytes from aviation, space and satellite, pharmaceutical, oil and gas, maritime and other technology targets; about 90 computers were accessed (Confirmed [66]; allegations). The campaign's alleged stages are spear-phishing attachments with spoofed senders, customized Poison Ivy variants and keyloggers that stole credentials, command servers on dynamic DNS, and exfiltration in encrypted archives. The indictment covers the whole campaign, so tying any stage to 2006 itself is this study's inference (Inferred [66]). ATT&CK's menuPass (G0045) page (version 3.0, modified 31 July 2026) says the group has been active since at least 2006, records the same Tianjin and Huaying Haitai ties, and lists PoisonIvy (S0012) among its software. PlugX belongs to the managed-service-provider campaign from 2014, not to 2006, and is not bound here (Confirmed [67]). The China-attributed actors study is the home (Confirmed [92]).

### Operation Shady RAT

McAfee's "Revealed: Operation Shady RAT" (Alperovitch, version 1.1, August 2011) rests on logs from one command server that show victims from mid-2006, when log collection began; McAfee says the activity may have started earlier (Confirmed [68]; the original address is dead and the paper was read from a Wayback capture). It names eight intrusions in 2006, among them South Korean construction and steel companies, a US Department of Energy research laboratory and an Asian trade organization (all July 2006), a US international trade organization (September), the ASEAN Secretariat (October, a month before its Singapore summit, lasting ten months) and a US real-estate firm (November). The table rows extracted number seven against the text's eight, and this study does not reconcile them (Confirmed [68]). McAfee describes the method as a spear-phishing e-mail carrying an exploit that downloads an implant, which talks to a command web server (Confirmed [68]). Its attribution is thin: it says only that the targeting of Olympic bodies "potentially pointed a finger at a state actor" and names no country (Confirmed [68]). The library's ATT&CK data has no group, software or campaign object for Shady RAT, and no study on main covers it (Demonstrated [93]; Confirmed [92]).

### The Athens wiretaps in 2006

Every item here is press reporting. The Intercept (28 September 2015) says Greece's Minister of Public Order George Voulgarakis and other officials disclosed the Vodafone Greece wiretaps at a televised press conference in February 2006, and that officials said the 14 shadow phones used four antennas covering about 2 km of central Athens (Reported [69]). It dates a parliamentary committee hearing with Vodafone Greece's CEO to 6 April 2006 and reports a June 2006 statement by Supreme Court prosecutor Dimitris Linos linking the tapping to the death of a Vodafone engineer; that is a statement, not a finding (Reported [69]). IEEE Spectrum's "The Athens Affair" (29 June 2007) reports the Ericsson Hellas CEO before the same committee on 6 April, the Vodafone CEO's newspaper interview in February, and Vodafone "fined 76 million" in December 2006, without naming the currency or regulator in the text read (Reported [70]). This study binds no ATT&CK object to the operation (Inferred). The 2005 chronicle is the home for the wiretaps' discovery in 2005, which it grades Reported (Confirmed [92]).

## Part 7: industrial systems and critical infrastructure

GAO-07-1036 records two 2006 industrial events (Confirmed [71]):

- **Browns Ferry (August).** Two circulation pumps at Unit 3 of the Browns Ferry nuclear plant in Alabama failed and forced a manual shutdown. GAO traces the failure to excessive traffic on the control system network, possibly caused by another control-system device failing, and does not describe it as an attack. The NRC's own notice was not opened.
- **Harrisburg (October).** A foreign hacker penetrated security at a water filtering plant in Harrisburg, Pennsylvania, and planted malicious software capable of affecting water treatment operations. The infection came through the internet and did not seem to target the control system directly.

The policy side moved in the same year. DHS ran Cyber Storm I in February, its first sponsored cyber exercise across the private sector and international, federal and state governments, with a scenario that hit the energy, IT, telecommunications and transportation sectors (Confirmed [16]). A Federal Register notice of 24 March established the Critical Infrastructure Partnership Advisory Council, and the first National Infrastructure Protection Plan followed in June (Confirmed [72]). DOE, DHS S&T and Natural Resources Canada published a ten-year Roadmap to Secure Control Systems in the Energy Sector, dated January 2006 from the PDF's metadata (Inferred [73]). The industrial thread runs on through Stuxnet, the ICS attacks and advisories study and the ICS ATT&CK Atlas (Inferred).

## Part 8: law, standards and the defender view

### Law

- **EU Data Retention Directive (15 March).** Directive 2006/24/EC entered into force on 3 May 2006 with a transposition deadline of 15 September 2007 (Confirmed [83]).
- **UK Police and Justice Act 2006 (8 November).** Sections 35 to 38 amend the Computer Misuse Act 1990: higher penalties for unauthorised access, a new section 3 offence of unauthorised acts with intent to impair a computer (up to ten years), and a new section 3A offence of making, supplying or obtaining articles for use in computer misuse (Confirmed [84]).
- **US e-discovery rules (1 December).** Amendments to the Federal Rules of Civil Procedure covering electronically stored information, adopted on 12 April, took effect on 1 December (Confirmed [85]).

### Standards

- **FIPS 200 (1 March).** Minimum Security Requirements for Federal Information and Information Systems, the second of the two FISMA-mandated standards; it supersedes SP 800-26 (Confirmed [77]).
- **RFC 4346 (April).** TLS 1.1 obsoletes TLS 1.0 (RFC 2246) and was later obsoleted by RFC 5246. It replaced the implicit CBC initialization vector with an explicit per-record one to guard against known CBC attacks, and made padding errors return bad_record_mac (Confirmed [86]).
- **SP 800-88 (31 August).** Guidelines for Media Sanitization, first final (Confirmed [80]).
- **SP 800-92 (13 September).** Guide to Computer Security Log Management (Confirmed [79]).
- **SP 800-100 (31 October).** Information Security Handbook: A Guide for Managers (Confirmed [81]).

- **SP 800-53 Revision 1 (19 December).** Recommended Security Controls for Federal Information Systems, aligned with FIPS 199 and FIPS 200; withdrawn on 19 December 2008 for Revision 2 (Confirmed [78]).
- **CWE (2006).** MITRE's history page dates the first CWE List and classification taxonomy to 2006, under the DHS and NIST SAMATE project, grown from the 2005 PLOVER document of more than 1,500 real-world examples (Confirmed [88]).

## The vendor side: Vista's defaults

A Microsoft security blog post of 26 May by Michael Howard says Windows Vista Beta 2 ships with ASLR on by default, so a DLL or EXE can load at any of 256 locations, alongside /GS stack checks, /SafeSEH, DEP/NX and encoding of long-lived function pointers (Confirmed [87]). The same post says DEP/NX stopped the author's own test WMF file on NX-capable hardware, the vendor's own account of the mitigation's value against that flaw class (Confirmed [87]).

## The defender view

**The breach was often a box of media.** The year's federal losses were a stolen laptop and drive, CDs, a thumb drive and more laptops (Confirmed [13][25]). Encryption at rest was OMB's first answer (Confirmed [75]). The privacy engineering reference covers data minimization and the GRC reference the control catalogs that followed FIPS 200 (Inferred).

**Notice was the failure that got graded.** VA's Inspector General found the notification neither appropriate nor timely and VA's safeguarding policies inadequate, and M-06-19 set a one-hour clock (Confirmed [25][76]). The incident response reference covers escalation paths (Inferred).

**Client-side zero-days needed a plan without a patch.** WMF, Word and VML were each exploited before a fix existed, and two needed out-of-cycle bulletins (Confirmed [1][28][31][40][41]). The memory protections Vista turned on by default are the D3FEND Harden techniques in Part 9 (Confirmed [87][96]). The Log4Shell study shows the same no-patch problem at larger scale (Inferred).

**A network service flaw meant worm risk.** MS06-040 was exploited at release, and F-Secure reports an IRC backdoor-worm variant that spreads with the MS06-040 exploit and points to it as of 13 August (Reported [38]); that it spread within days is this study's reading (Inferred). Blocking 139 and 445 at the edge and on hosts was the advice (Confirmed [35]). The vulnerability management reference covers prioritizing by exploitation (Inferred).

**The card path was watched by the attacker, not the defender.** TJX's intruder intercepted authorization traffic for months, and discovery came in December (Confirmed [56][54]). NIST's log management guide came out the same September (Confirmed [79]).

**Insiders and their contractors are part of the threat model.** VA's analyst took data home without authorization, USDA's FOIA official told a contractor not to tell management, and a third party retained by HP's outside investigators used pretexting (Confirmed [20][13][51]).

## Part 9: MITRE mappings

No 2006 record opened here carries an ATT&CK or CAPEC id, and the first CWE List came out during the year (Confirmed [88]; the CAPEC point is Inferred, since [89] gives no release date). Every Enterprise binding below is this study's later mapping (Inferred), apart from the objects ATT&CK itself dates to 2006 (Confirmed [64][67]). Every id was checked against the library's data files and the generated pages under `mitre/` (Demonstrated [93][94][98]). Names and tactics are those of ATT&CK v20.0 as the library carries them.

The Basis column says how strong each tie is, as in the 2016 chronicle. **Listed** means ATT&CK itself lists the id for the object. **Described** means a primary source describes the behavior and this study assigns the id. **Reported** means only a secondary source supports the behavior. **Inferred** means no source describes the behavior in enough detail and the mapping rests on this study's reading.

## ATT&CK Enterprise techniques

| Id | Name (ATT&CK v20.0) | Tactic(s) | Basis | Dated event or report | Sources |
|---|---|---|---|---|---|
| T1203 | Exploitation for Client Execution | execution | Described | WMF (5 Jan), IE createTextRange (11 Apr), Word (19 May to 13 Jun), Excel (11 Jul), PowerPoint (8 Aug, 10 Oct), VML (19 to 26 Sep) and WebViewFolderIcon (10 Oct), each exploited at release | [3][18][28][34][39][41][43][44] |
| T1189 | Drive-by Compromise | initial-access | Described | MS06-001 lists a malicious web page as a vector of the exploited WMF flaw (5 Jan); the VML flaw exploited through Internet Explorer (19 Sep) | [3][40][41] |
| T1566.001 | Spearphishing Attachment | initial-access | Described | The APT10 "Technology Theft Campaign" from about 2006 (alleged); Shady RAT from mid-2006; APT1, most common way in, 2006 to 2013; the targeted Word attack (21 May, Reported) | [66][68][61][30] |
| T1204.002 | Malicious File | execution | Described | MS06-027 needs a user to open a crafted Word document (13 Jun); the APT10 campaign (alleged) | [28][66][67] |
| T1210 | Exploitation of Remote Services | lateral-movement | Described | MS06-040 Server service flaw exploited at release (8 Aug); IRCBot.ST spreading through it (13 Aug, Reported) | [35][36][38] |
| T1071 | Application Layer Protocol | command-and-control | Reported | IRCBot.ST is an IRC-controlled backdoor-worm (Aug) | [38] |
| T1584.005 | Botnet | resource-development | Described | Ancheta's botnets sold for DDoS and spam (sentenced 8 May); Maxwell's adware botnet (indicted 10 Feb, plea 4 May) | [26][14][15] |
| T1498 | Network Denial of Service | impact | Described | Botnet access sold for DDoS (Ancheta, 8 May); the Russian bookmaker extortion (Oct, Reported) | [26][59] |
| T1485 | Data Destruction | impact | Described | Mywife.E corrupts common document files on the 3rd of each month, first on 3 Feb | [6][7] |
| T1685 | Disable or Modify Tools | defense-impairment | Described | Mywife.E disables security software (Advisory 904420, 30 Jan) | [6] |
| T1021.002 | SMB/Windows Admin Shares | lateral-movement | Inferred | Mywife.E spreads over writable shares and blank Administrator passwords; the advisory does not name the share type | [6] |

| Id | Name (ATT&CK v20.0) | Tactic(s) | Basis | Dated event or report | Sources |
|---|---|---|---|---|---|
| T1040 | Network Sniffing | credential-access, discovery | Described | TJX: card authorization requests intercepted in transit, May to Dec 2006 (FTC complaint) | [56] |
| T1074 | Data Staged | collection | Described | TJX: intercepted data stored in files on the network before transfer (FTC complaint) | [56] |
| T1583.001 | Domains | resource-development | Described | APT1's sb.hugesoft.org registered to the UglyGorilla persona, in the 2006 Symantec Japan writeup Mandiant cites; ATT&CK lists the id for G0006 and G0045 | [61][63][67] |
| T1568.001 | Fast Flux DNS | command-and-control | Inferred | APT10 command servers on dynamic DNS (alleged); the v20 name differs from the behavior, and the menuPass procedure under this id covers dynamic DNS | [66][67] |
| T1056.001 | Keylogging | collection, credential-access | Described | APT10 keyloggers that stole credentials (alleged, campaign from about 2006) | [66][67] |
| T1560 | Archive Collected Data | collection | Described | APT10 exfiltration in encrypted archives (alleged) | [66][67] |
| T1105 | Ingress Tool Transfer | command-and-control | Listed (software) | WEBC2, used by APT1 as early as July 2006; tying the id to the 2006 instance is Inferred | [64][61] |
| T1059.003 | Windows Command Shell | execution | Listed (software) | WEBC2, as above | [64][61] |
| T1574.001 | DLL | stealth, execution | Listed (software) | WEBC2, as above | [64][61] |

Left out on purpose: T1486 Data Encrypted for Impact for Gpcode, because no source opened here dates it (Reported [8]). An exfiltration technique for TJX, because the FTC says files went over the internet without naming the channel (Confirmed [56]). T1059.007 for the eBay scripts, because US-CERT describes a risk, not observed use (Confirmed [19]). Network scanning for Maxwell's botnet, because the release does not describe the scanning beyond its effect (Confirmed [15]). The VA theft and the other federal losses, which were physical thefts and losses with no ATT&CK technique (Confirmed [13]). HP's pretexting, which targeted telephone carriers' records, not an enterprise system (Confirmed [51]; Inferred). McKinnon, Levine, Bailey and Benimeli, whose records name no method (Confirmed [27][17][33][60]). The Athens wiretaps, whose only sources are Reported (Reported [69][70]).

## Techniques ATT&CK lists for objects it dates to the period

ATT&CK draws these from later analyses, not from a dated 2006 event, so they are not in this study's Navigator layer (Confirmed [63][67]; Inferred).

| Id | Name (ATT&CK v20.0) | Tactic(s) | Object | Basis | Sources |
|---|---|---|---|---|---|
| T1566.002 | Spearphishing Link | initial-access | G0006 APT1 | Listed (group); Mandiant describes links to malicious files across 2006 to 2013 | [63][61] |
| T1036.005 | Match Legitimate Resource Name or Location | stealth | G0006 APT1; G0045 menuPass | Listed (group) | [63][67] |
| T1560.001 | Archive via Utility | collection | G0006 APT1; G0045 menuPass | Listed (group) | [63][67] |

## ATT&CK for ICS

No 2006 event in the record opened here is a documented attack on an industrial control system. GAO traces Browns Ferry to excessive control-network traffic, possibly from a failing device, and GAO says the Harrisburg malware came in through the internet and did not seem to target the control system directly (Confirmed [71]). This study therefore has no ATT&CK for ICS table and no ICS layer (Inferred).

## ATT&CK groups, software and campaigns

| Object | Id | Binding | Sources |
|---|---|---|---|
| APT1 | G0006 | Bound with a caveat: Mandiant's visibility starts in 2006; ATT&CK gives no start year; attribution to Unit 61398 is Mandiant's and ATT&CK's assessment and a 2014 indictment's allegation | [61][62][63] |
| WEBC2 | S0109 | Bound: ATT&CK says APT1 used it as early as July 2006 | [64][61] |
| menuPass | G0045 | Bound with a caveat: ATT&CK says active since at least 2006; the APT10 indictment alleges a campaign from about 2006 | [65][66][67] |
| PoisonIvy | S0012 | Bound with a caveat: the indictment's customized Poison Ivy variants belong to a campaign that began about 2006; no 2006-dated sample is named | [66][67][63] |

No campaign object is bound; the library's campaign data has none for 2004 to 2007 (Demonstrated [93]). PlugX (S0013) is not bound because ATT&CK places it in menuPass's campaign from 2014 (Confirmed [67]). The library's software data has no ATT&CK object for Mywife.E or Nyxem, Gpcode, IRCBot or Mocbot, or Ancheta's and Maxwell's bots, and no group object for Shady RAT (Demonstrated [93]).

## CWE and CAPEC

Rows marked NVD carry the CWE NVD lists; others are this study's classes (Inferred). Names are those in the library's CWE and CAPEC data, and every CAPEC listed has a page under `/mitre/capec/` (Demonstrated [97][94]). The library has no per-CWE generated pages, so CWE ids are plain text; the CWE reference is the library's entry point (Confirmed [97]). The library's CAPEC-100 page lists CWE-119 and CWE-120 among its related weaknesses and links CAPEC-8, which ties CAPEC-100 to the two 2006 overflow CVEs (Inferred [95]).

| CWE | Weakness (library name) | Basis | 2006 record | CAPEC |
|---|---|---|---|---|
| CWE-20 | Improper Input Validation | NVD | Windows Metafile (CVE-2005-4560) | None assigned |

| CWE | Weakness (library name) | Basis | 2006 record | CAPEC |
|---|---|---|---|---|
| CWE-120 | Buffer Copy without Checking Size of Input | NVD | Word (CVE-2006-2492) | CAPEC-100 Overflow Buffers (the library lists CWE-120 on it); CAPEC-8 Buffer Overflow in an API Call (linked from CAPEC-100) |
| CWE-119 | Improper Restriction of Operations within the Bounds of a Memory Buffer | NVD | VML (CVE-2006-4868) | CAPEC-100 Overflow Buffers (the library lists CWE-119 on it) |
| CWE-94 | Improper Control of Generation of Code | NVD | IE createTextRange (CVE-2006-1359); WebViewFolderIcon (CVE-2006-3730) | CAPEC-242 Code Injection (this study's pairing) |
| NVD-CWE-Other | (as NVD lists it) | NVD | Server service (CVE-2006-3439) | See CWE-121 |
| CWE-121 | Stack-based Buffer Overflow | Study's class | Server service, which CERT/CC describes as a stack buffer overflow | CAPEC-100 Overflow Buffers |
| NVD-CWE-noinfo | (as NVD lists it) | NVD | MDAC RDS.Dataspace (CVE-2006-0003) | None assigned |
| CWE-79 | Improper Neutralization of Input During Web Page Generation | Study's class | Scripts in eBay postings (US-CERT, 27 Apr) | CAPEC-63 Cross-Site Scripting (XSS) |
| CWE-89 | Improper Neutralization of Special Elements used in an SQL Command | Study's class, Inferred only | CardSystems: the FTC names SQL injection among known attacks the company failed to assess, not as the confirmed vector | CAPEC-66 SQL Injection |
| none bound | (phishing) | Library data | Targeted Word e-mail; APT10 and Shady RAT spear phishing | CAPEC-163 Spear Phishing (the library lists it on T1566.001 and T1566.002) |
| none bound | (shares) | Library data | Mywife.E spreading through shares and blank Administrator passwords | CAPEC-561 Windows Admin Shares with Stolen Credentials (the library lists it on T1021.002) |
| none bound | (security tools disabled) | Library data | Mywife.E disabling security software | CAPEC-578 Disable Security Software (the library lists it on T1685) |
| none bound | (sniffing) | Library data | TJX interception | CAPEC-158 Sniffing Network Traffic (the library lists it on T1040) |
| none bound | (keylogging) | Library data | APT10 keyloggers (alleged) | CAPEC-568 Capture Credentials via Keylogger (the library lists it on T1056.001) |
| none bound | (flooding) | Study's pairing | Ancheta's DDoS sales; the bookmaker extortion | CAPEC-125 Flooding |

NVD assigned these CWE ids after the fact: the CWE List itself dates from 2006 (Confirmed [88]; Inferred for the assignment dates).

## D3FEND countermeasures

The technique-to-countermeasure links come from the library's D3FEND data; pairing them with the 2006 advice is this study's reading (Confirmed [96]; Inferred). Every page exists under `/mitre/d3fend/` (Demonstrated [94]).

| Technique from the record | D3FEND countermeasures (D3FEND tactic) | 2006 analogue |
|---|---|---|
| T1203, T1189 | Process Segment Execution Prevention (Harden); Segment Address Offset Randomization (Harden) | DEP/NX and ASLR, on by default in Vista; DEP stopped Microsoft's test WMF file [87] |
| T1203 | Stack Frame Canary Validation (Harden) | The /GS stack checks in the same post [87] |
| T1210, T1189 | Network Traffic Filtering (Isolate) | MS06-040's workaround: block TCP 139 and 445 [35] |
| T1210 | Connection Attempt Analysis (Detect) | Watching for worm connections on the ports MS06-040 named (Inferred) [35][38] |
| T1566.001 | Email Filtering (Isolate); File Analysis (Detect) | The targeted Word attachments of May [30] |
| T1204.002 | Executable Allowlisting (Isolate); File Analysis (Detect) | The code dropped by exploited Office documents [30][39] |

The library links T1584.005, T1498, T1485, T1685, T1021.002 and T1074 to no D3FEND countermeasure, and T1040 only to DNS Traffic Analysis, which has no 2006 analogue here (Demonstrated [96]). ATT&CK mitigation pages exist for M1051 Update Software, M1037 Filter Network Traffic, M1050 Exploit Protection, M1049 Antivirus/Antimalware, M1017 User Training, M1041 Encrypt Sensitive Information, M1032 Multi-factor Authentication and M1027 Password Policies (Demonstrated [94]). M-06-16's encryption and two-factor controls map most closely to M1041 and M1032, Vista's defaults to M1050, and the blank Administrator passwords Mywife.E used to M1027 (Inferred [75][87][6]).

## Navigator layer

The study's Enterprise techniques are saved as one ATT&CK Navigator layer pinned to ATT&CK v20, navigator/library-layers/chronicle-2006.json, in the format of the existing chronicle layers: domain enterprise-attack, navigator 4.9, layer 4.5, described as a curated case-study layer and not an official MITRE mapping (Demonstrated [99]). It lists the 20 techniques in the Enterprise table under each tactic they carry in v20.0, 23 technique-tactic entries in all, and is listed on the Navigator layers page. The three techniques in the second table are not in it. Scores show the basis, not severity, in the house scale set by the 2016 chronicle: 100 where the source or ATT&CK object prints the id, 70 where a primary source describes the behavior and this study assigns the id, 50 where only a Reported source supports it, and 40 for an Inferred mapping (Demonstrated [99]). No 2006 source prints an ATT&CK id. ATT&CK's WEBC2 page prints three ids for the software but does not tie them to the July 2006 sighting, so this study holds those three rows at 70 rather than 100, and no technique scores 100 (Inferred). T1071 scores 50; T1021.002 and T1568.001 score 40; every other row scores 70. Each entry's comment names the source numbers in the Sources table below. No ICS layer is needed (Inferred).

## Cross-cutting themes

**Losing data and having it stolen were treated alike.** The VA burglary and the federal media losses ended in notice letters, and VA's in a year of credit monitoring; ChoicePoint's fraud ended in an FTC order with redress and a security program (Confirmed [13][23][10][9]). In 2006 the response to a loss did not depend on whether an attacker was involved (Inferred).

**The document became the exploit.** WMF images, Word, Excel and PowerPoint files and a VML page were all exploited before a fix existed (Confirmed [3][28][34][39][44][41]); CERT/CC records the WMF exploit working on fully patched Windows XP SP2 (Confirmed [1]). Opening an ordinary document or web page was enough to run an attacker's code (Inferred).

**The state record was written in arrears.** APT1, menuPass and Shady RAT all start in 2006 in records published in 2011, 2013, 2014 and 2018 (Confirmed [68][61][62][65][66]). Nothing opened here shows a 2006 public record naming any of them, apart from the Symantec Japan writeup Mandiant cites (Confirmed [61]; Inferred).

**Botnets and extortion were becoming businesses.** Ancheta sold access, Maxwell harvested adware commissions, and the Russian bookmaker case was DDoS for ransom (Confirmed [26][14]; Reported [59]).

**The plumbing of later security work kept arriving.** FIPS 200, SP 800-53 Revision 1, SP 800-92, SP 800-88, TLS 1.1, the first CWE List, the PCI Council and Vista's default ASLR all date from 2006 (Confirmed [77][78][79][80][86][88][82][87]).

### What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: the VA theft as a hack.** It was a burglary of equipment taken home without authorization; VA believed the burglars did not target the data, and the FBI found the files had not been compromised [20][25].
- **Overstated: the CVE count as a measure of risk.** NVD published 6,659 records in 2006, but only two CVE-2006 ids are in KEV [50][32].
- **Overstated: "since 2006" as APT1's start date.** Mandiant says 2006 is where its visibility begins, not necessarily where the activity began; the first WEBC2-KT3 compile time is from 2004 [61].
- **Overstated: Shady RAT as a state attribution.** McAfee names no country and rests on one server's logs that start in mid-2006 [68].
- **Overstated: the Athens wiretap details.** Every 2006 date and figure here comes from press accounts published in 2007 and 2015 [69][70].
- **Overstated: the precision of ids on 2006 events.** Every ATT&CK and CAPEC id here is retrospective, NVD's CWE ids were assigned after the CWE List existed, and CVSS v2 and KEV came later still [88][90][32].
- **Understated: Office as the attack surface.** Four Office bulletins in five months fixed flaws already being exploited, and the May Word attack was targeted [28][34][39][44][30].
- **Understated: the out-of-cycle releases.** Microsoft broke its monthly cycle twice for flaws already being exploited [3][41].

- **Understated: the start of long espionage campaigns.** APT1 average access of 356 days and an APT10 campaign touching more than 45 entities both begin, as later records date them, in 2006 [61][66].
- **Understated: TJX's year of interception.** The intruder took card data from May to December 2006 and was found only at the end of the year [56][54].
- **Understated: the basics.** Vista's default memory protections, SP 800-92 on logs, SP 800-88 on media sanitization and the first CWE vocabulary get a line each against many for the breaches, yet later work relies on them [87][79][80][88].
- **Understated: what investigators may do.** HP's pretexting shows a company's own inquiry can become the privacy breach [51].

### Discrepancies in the record

- **VA's total.** Up to 26.5 million in VA's 22 May statement; about 26 million veterans and military personnel in the Inspector General's report [20][25].
- **VA's service-member estimate.** 10,000 to 20,000 Guard and Reserve and 25,000 to 30,000 Navy personnel on 3 June; 1.1 million active duty, 430,000 Guard and 645,000 Reserve on 6 June after Defense Department matching [21][22].
- **Maxwell's damage figure.** The plea release gives both more than $135,000 of damage to military computers and $138,000 to repair more than 400 Defense Department computers; it does not reconcile the two [15].
- **Mywife.E's dating.** Microsoft's advisory dates the payload from 3 February 2006; F-Secure's summary says the variant was found in September 2004 [6][7].
- **The Word zero-day's dates.** ISC first reported it on 19 May (per NVD), NVD published the CVE on 20 May, and the ISC diary opened here is dated 21 May [31][30].
- **TJX's window.** The 10-K puts intruder access from mid-May 2006 to mid-January 2007; the FTC puts interception from May to December 2006 [54][56].
- **M-06-16's date.** The memorandum is dated 23 June; the PDF's metadata says 26 June [75].
- **Shady RAT's 2006 count.** Eight intrusions in the text; seven rows extracted from the table [68].
- **The PCI Council's month.** Founded in 2006 by the brands' own page; September 2006 in the library's e-commerce study [82][91].
- **The WMF alert's id.** US-CERT's alert is dated 5 January but carries the id TA06-006A [4].

## Sources

Sources were opened on 12 and 13 November 2026, and the library data checks were run on 12 and 13 November 2026 as the Opened column shows. All are checked as of 13 November 2026. Grade is the source's evidence grade as used in this study. Addresses shown as code rather than as links refuse automated link checkers (the three ftc.gov releases and the FTC's TJX complaint, the three gao.gov reports, the six sec.gov filings and McAfee's retired white-paper address); copy them into a browser to open them.

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 1 | CERT/CC, VU#181038 (Windows Metafile) | https://www.kb.cert.org/vuls/id/181038 | 2026-11-12 | Confirmed |
| 2 | Microsoft Security Advisory 912840 (WMF) | https://learn.microsoft.com/en-us/security-updates/securityadvisories/2005/912840 | 2026-11-12 | Confirmed |
| 3 | Microsoft Security Bulletin MS06-001 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-001 | 2026-11-12 | Confirmed; Inferred (out of cycle) |
| 4 | US-CERT, Microsoft Windows Metafile Vulnerability, 5 Jan 2006 (CISA archive) | https://www.cisa.gov/news-events/alerts/2006/01/05/microsoft-windows-metafile-vulnerability | 2026-11-12 | Confirmed |
| 5 | NVD, CVE-2005-4560 (record and API) | https://nvd.nist.gov/vuln/detail/CVE-2005-4560 ; https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2005-4560 | 2026-11-12 | Confirmed |
| 6 | Microsoft Security Advisory 904420 (Win32/Mywife.E@mm) | https://learn.microsoft.com/en-us/security-updates/securityadvisories/2006/904420 | 2026-11-12 | Confirmed |
| 7 | F-Secure, Nyxem.E description | https://www.f-secure.com/v-descs/nyxem_e.shtml | 2026-11-12 | Reported |
| 8 | F-Secure, Gpcode description | https://www.f-secure.com/v-descs/gpcode.shtml | 2026-11-12 | Reported |
| 9 | ChoicePoint Inc., Form 8-K on the FTC settlement, Jan 2006 (SEC EDGAR) | `https://www.sec.gov/Archives/edgar/data/1040596/000095014406000610/g99324e8vk.htm` | 2026-11-12 | Confirmed |
| 10 | FTC, "ChoicePoint Settles Data Security Breach Charges", 26 Jan 2006 | `https://www.ftc.gov/news-events/news/press-releases/2006/01/choicepoint-settles-data-security-breach-charges-pay-10-million-civil-penalties-5-million-consumer` | 2026-11-12 | Confirmed |
| 11 | FTC, ChoicePoint redress program, 6 Dec 2006 | `https://www.ftc.gov/news-events/news/press-releases/2006/12/ftc-launches-redress-program-choicepoint-identity-theft-victims` | 2026-11-12 | Confirmed |
| 12 | FTC, "CardSystems Solutions Settles FTC Charges", 23 Feb 2006 | `https://www.ftc.gov/news-events/news/press-releases/2006/02/cardsystems-solutions-settles-ftc-charges` | 2026-11-12 | Confirmed; Inferred (the CWE-89 class) |
| 13 | GAO, GAO-07-657, Privacy: Lessons Learned about Data Breach Notification | `https://www.gao.gov/assets/gao-07-657.pdf` | 2026-11-12 | Confirmed |
| 14 | DOJ, Maxwell indictment, 10 Feb 2006 | https://www.justice.gov/archive/criminal/cybercrime/press-releases/2006/maxwellIndict.htm | 2026-11-12 | Confirmed (as alleged) |
| 15 | DOJ, Maxwell plea, 4 May 2006 | https://www.justice.gov/archive/criminal/cybercrime/press-releases/2006/maxwellPlea.htm | 2026-11-12 | Confirmed |
| 16 | CISA, Cyber Storm I | https://www.cisa.gov/cyber-storm-i | 2026-11-12 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 17 | DOJ, Levine sentence, 22 Feb 2006 | https://www.justice.gov/archive/criminal/cybercrime/press-releases/2006/levineSent.htm | 2026-11-12 | Confirmed |
| 18 | Microsoft Security Bulletin MS06-013 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-013 | 2026-11-12 | Confirmed |
| 19 | US-CERT, Scripts in eBay Postings May Enable Phishing Attacks, 27 Apr 2006 | https://www.cisa.gov/news-events/alerts/2006/04/27/scripts-ebay-postings-may-enable-phishing-attacks | 2026-11-12 | Confirmed |
| 20 | VA, "A Statement from the Department of Veterans Affairs", 22 May 2006 | https://news.va.gov/press-room/a-statement-from-the-department-of-veterans-affairs/ | 2026-11-12 | Confirmed |
| 21 | VA, update on the stolen data incident, 3 Jun 2006 | https://news.va.gov/press-room/secretary-nicholson-provides-update-on-stolen-data-incident-vas-investigation-providing-new-details-about-information-potentially-involved/ | 2026-11-12 | Confirmed |
| 22 | VA, update on the stolen data incident, 6 Jun 2006 | https://news.va.gov/press-room/secretary-nicholson-provides-update-on-stolen-data-incident-data-matching-with-department-of-defense-providing-new-details/ | 2026-11-12 | Confirmed |
| 23 | VA, free credit monitoring, 21 Jun 2006 | https://news.va.gov/press-room/secretary-nicholson-announces-va-to-provide-free-credit-monitoring/ | 2026-11-12 | Confirmed |
| 24 | GAO, GAO-06-897T | `https://www.gao.gov/products/gao-06-897t` | 2026-11-12 | Confirmed |
| 25 | VA OIG, Review of Issues Related to the Loss of VA Information, Report 06-02238-163, 11 Jul 2006 | https://www.vaoig.gov/sites/default/files/reports/2006-07/VAOIG-06-02238-163.pdf | 2026-11-12 | Confirmed |
| 26 | DOJ, Ancheta sentence, 8 May 2006 | https://www.justice.gov/archive/criminal/cybercrime/press-releases/2006/anchetaSent.htm | 2026-11-12 | Confirmed |
| 27 | House of Lords, McKinnon v Government of the USA [2008] UKHL 59 | https://publications.parliament.uk/pa/ld200708/ldjudgmt/jd080730/mckinn-1.htm | 2026-11-12 | Confirmed (as alleged) |
| 28 | Microsoft Security Bulletin MS06-027 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-027 | 2026-11-12 | Confirmed |
| 29 | CERT/CC, VU#446012 (Microsoft Word) | https://www.kb.cert.org/vuls/id/446012 | 2026-11-12 | Confirmed |
| 30 | SANS Internet Storm Center, diary 1345, 21 May 2006 | https://isc.sans.edu/diary/1345 | 2026-11-12 | Reported |
| 31 | NVD, CVE-2006-2492 (record and API) | https://nvd.nist.gov/vuln/detail/CVE-2006-2492 ; https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2006-2492 | 2026-11-12 | Confirmed |
| 32 | CISA, Known Exploited Vulnerabilities catalog (JSON, version 2026.11.10) | https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json | 2026-11-12 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 33 | DOJ, Bailey indictment, 15 Jun 2006 | https://www.justice.gov/archive/criminal/cybercrime/press-releases/2006/baileyCharge.htm | 2026-11-12 | Confirmed (as alleged) |
| 34 | Microsoft Security Bulletin MS06-037 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-037 | 2026-11-12 | Confirmed |
| 35 | Microsoft Security Bulletin MS06-040 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-040 | 2026-11-12 | Confirmed |
| 36 | CERT/CC, VU#650769 (Server service) | https://www.kb.cert.org/vuls/id/650769 | 2026-11-12 | Confirmed |
| 37 | NVD API, CVE-2006-3439 | https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2006-3439 | 2026-11-12 | Confirmed |
| 38 | F-Secure, IRCBot.ST description | https://www.f-secure.com/v-descs/ircbot_st.shtml | 2026-11-12 | Reported |
| 39 | Microsoft Security Bulletin MS06-048 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-048 | 2026-11-12 | Confirmed |
| 40 | US-CERT, Microsoft Internet Explorer VML Buffer Overflow, 19 Sep 2006 | https://www.cisa.gov/news-events/alerts/2006/09/19/microsoft-internet-explorer-vml-buffer-overflow | 2026-11-12 | Confirmed |
| 41 | Microsoft Security Bulletin MS06-055 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-055 | 2026-11-12 | Confirmed; Inferred (out of cycle) |
| 42 | NVD API, CVE-2006-4868 | https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2006-4868 | 2026-11-12 | Confirmed |
| 43 | Microsoft Security Bulletin MS06-057 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-057 | 2026-11-12 | Confirmed |
| 44 | Microsoft Security Bulletin MS06-060 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-060 | 2026-11-12 | Confirmed |
| 45 | Microsoft Security Bulletin MS06-014 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-014 | 2026-11-12 | Confirmed |
| 46 | NVD API, CVE-2006-0003 | https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2006-0003 | 2026-11-12 | Confirmed |
| 47 | CERT/CC, VU#834865 (Sendmail) | https://www.kb.cert.org/vuls/id/834865 | 2026-11-12 | Confirmed |
| 48 | CERT/CC, VU#867796 (Apple AirPort) | https://www.kb.cert.org/vuls/id/867796 | 2026-11-12 | Confirmed |
| 49 | Microsoft Security Bulletin MS06-078 | https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-078 | 2026-11-12 | Confirmed; Inferred (the bulletin count) |
| 50 | NVD CVE API 2.0, records published in 2006, by quarter (1,381; 1,811; 1,627; 1,840) and in four other date windows (1,959; 2,216; 2,276; 208) | https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2006-01-01T00:00:00.000&pubEndDate=2006-03-31T23:59:59.999 ; https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2006-01-01T00:00:00.000Z&pubEndDate=2006-04-30T23:59:59.999Z&resultsPerPage=1 | 2026-11-12 | Confirmed; Demonstrated |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 51 | Hewlett-Packard, Form 8-K filed 6 Sep 2006 (SEC EDGAR) | https://www.sec.gov/Archives/edgar/data/47217/000110465906059471/a06-19246_18k.htm | 2026-11-12 | Confirmed |
| 52 | Hewlett-Packard, Form 8-K, 12 Sep 2006 (SEC EDGAR) | https://www.sec.gov/Archives/edgar/data/47217/000110465906060568/a06-19530_18k.htm | 2026-11-12 | Confirmed |
| 53 | Hewlett-Packard, Form 8-K, 27 Sep 2006 (SEC EDGAR) | https://www.sec.gov/Archives/edgar/data/47217/000110465906063490/a06-20344_18k.htm | 2026-11-12 | Confirmed |
| 54 | The TJX Companies, Form 10-K for fiscal 2007 (SEC EDGAR) | https://www.sec.gov/Archives/edgar/data/109198/000095013507001906/b64407tje10vk.htm | 2026-11-12 | Confirmed |
| 55 | The TJX Companies, Form 8-K filed 18 Jan 2007 (SEC EDGAR) | https://www.sec.gov/Archives/edgar/data/109198/000095013507000226/b63779txe8vk.htm | 2026-11-12 | Confirmed |
| 56 | FTC, complaint in In the Matter of The TJX Companies | https://www.ftc.gov/sites/default/files/documents/cases/2008/08/080801tjxcomplaint.pdf | 2026-11-12 | Confirmed (as alleged); Inferred (the technique mapping) |
| 57 | DOJ, charges against Albert Gonzalez and ten others, 5 Aug 2008 | https://www.justice.gov/archive/opa/pr/2008/August/08-ag-689.html | 2026-11-12 | Confirmed (as alleged) |
| 58 | DOJ, Butler indictment, 11 Sep 2007 | https://www.justice.gov/archive/criminal/cybercrime/press-releases/2007/butlerIndict.htm | 2026-11-12 | Confirmed (as alleged) |
| 59 | Out-Law (Pinsent Masons), "Russian bookmaker hackers jailed for eight years", 5 Oct 2006 | https://www.pinsentmasons.com/out-law/news/russian-bookmaker-hackers-jailed-for-eight-years | 2026-11-12 | Reported |
| 60 | DOJ, Benimeli indictment, 7 Feb 2006 (served under a mismatched file name) | https://www.justice.gov/archive/criminal/cybercrime/press-releases/2006/anchetaPlea.htm | 2026-11-12 | Confirmed (as alleged) |
| 61 | Mandiant, "APT1: Exposing One of China's Cyber Espionage Units", Feb 2013 | https://services.google.com/fh/files/misc/mandiant-apt1-report.pdf | 2026-11-12 | Confirmed; Inferred (the Wualess month) |
| 62 | DOJ, charges against five PLA officers, 19 May 2014 (read from a Wayback capture) | https://www.justice.gov/opa/pr/us-charges-five-chinese-military-hackers-cyber-espionage-against-us-corporations-and-labor | 2026-11-12 | Confirmed (as alleged) |
| 63 | MITRE ATT&CK, APT1 (G0006) | https://attack.mitre.org/groups/G0006/ | 2026-11-12 | Confirmed |
| 64 | MITRE ATT&CK, WEBC2 (S0109) | https://attack.mitre.org/software/S0109/ | 2026-11-12 | Confirmed; Inferred (the 2006 tie) |
| 65 | DOJ, charges against two APT10 members, 20 Dec 2018 (read from a Wayback capture) | https://www.justice.gov/opa/pr/two-chinese-hackers-associated-ministry-state-security-charged-global-computer-intrusion | 2026-11-12 | Confirmed (as alleged) |
| 66 | DOJ, indictment of Zhu Hua and Zhang Shilong (S.D.N.Y.) (read from a Wayback capture) | https://www.justice.gov/opa/press-release/file/1121706/download | 2026-11-12 | Confirmed (as alleged); Inferred (the 2006 tie of each stage) |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 67 | MITRE ATT&CK, menuPass (G0045) | https://attack.mitre.org/groups/G0045/ | 2026-11-12 | Confirmed |
| 68 | McAfee, "Revealed: Operation Shady RAT", v1.1, Aug 2011 (read from a Wayback capture) | `http://www.mcafee.com/us/resources/white-papers/wp-operation-shady-rat.pdf` | 2026-11-12 | Confirmed; Inferred (the technique mapping) |
| 69 | The Intercept, "A Death in Athens", 28 Sep 2015 | https://theintercept.com/2015/09/28/death-athens-rogue-nsa-operation/ | 2026-11-12 | Reported |
| 70 | IEEE Spectrum, "The Athens Affair", 29 Jun 2007 | https://spectrum.ieee.org/the-athens-affair | 2026-11-12 | Reported |
| 71 | GAO, GAO-07-1036, Critical Infrastructure Protection: Multiple Efforts to Secure Control Systems | `https://www.gao.gov/assets/gao-07-1036.pdf` | 2026-11-12 | Confirmed |
| 72 | DHS, National Infrastructure Protection Plan, 2009 | https://www.dhs.gov/xlibrary/assets/NIPP_Plan.pdf | 2026-11-12 | Confirmed |
| 73 | DOE, Roadmap to Secure Control Systems in the Energy Sector | https://www.energy.gov/sites/prod/files/oeprod/DocumentsandMedia/roadmap.pdf | 2026-11-12 | Inferred (the month) |
| 74 | The White House, executive order on identity theft, 10 May 2006 | https://georgewbush-whitehouse.archives.gov/news/releases/2006/05/20060510-3.html | 2026-11-12 | Confirmed |
| 75 | OMB, M-06-16, Protection of Sensitive Agency Information | https://georgewbush-whitehouse.archives.gov/omb/memoranda/fy2006/m06-16.pdf | 2026-11-12 | Confirmed |
| 76 | OMB, M-06-19, Reporting Incidents Involving Personally Identifiable Information | https://georgewbush-whitehouse.archives.gov/omb/memoranda/fy2006/m06-19.pdf | 2026-11-12 | Confirmed |
| 77 | NIST, FIPS 200 | https://csrc.nist.gov/pubs/fips/200/final | 2026-11-12 | Confirmed |
| 78 | NIST, SP 800-53 Revision 1 | https://csrc.nist.gov/pubs/sp/800/53/r1/final | 2026-11-12 | Confirmed |
| 79 | NIST, SP 800-92 | https://csrc.nist.gov/pubs/sp/800/92/final | 2026-11-12 | Confirmed |
| 80 | NIST, SP 800-88 | https://csrc.nist.gov/pubs/sp/800/88/final | 2026-11-12 | Confirmed |
| 81 | NIST, SP 800-100 | https://csrc.nist.gov/pubs/sp/800/100/final | 2026-11-12 | Confirmed |
| 82 | PCI Security Standards Council, About Us | https://www.pcisecuritystandards.org/about_us/ | 2026-11-12 | Confirmed |
| 83 | Publications Office of the EU, Directive 2006/24/EC | https://publications.europa.eu/resource/celex/32006L0024 | 2026-11-12 | Confirmed |
| 84 | legislation.gov.uk, Police and Justice Act 2006 (contents; Part 5, computer misuse) | https://www.legislation.gov.uk/ukpga/2006/48/contents ; https://www.legislation.gov.uk/ukpga/2006/48/part/5/crossheading/computer-misuse | 2026-11-12 | Confirmed |
| 85 | Cornell LII, Federal Rules of Civil Procedure, Rule 34 | https://www.law.cornell.edu/rules/frcp/rule_34 | 2026-11-12 | Confirmed |
| 86 | RFC Editor, RFC 4346 | https://www.rfc-editor.org/rfc/rfc4346 | 2026-11-12 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 87 | Microsoft, Michael Howard, "Address Space Layout Randomization in Windows Vista", 26 May 2006 | https://learn.microsoft.com/en-us/archive/blogs/michael_howard/address-space-layout-randomization-in-windows-vista | 2026-11-12 | Confirmed; Inferred (the overstated and understated reading) |
| 88 | MITRE, CWE history | https://cwe.mitre.org/about/history.html | 2026-11-12 | Confirmed |
| 89 | MITRE, CAPEC archive | https://capec.mitre.org/data/archive.html | 2026-11-12 | Confirmed |
| 90 | FIRST, CVSS v2 | https://www.first.org/cvss/v2/ | 2026-11-12 | Confirmed |
| 91 | TeamStarWolf library, `case-studies/ECOMMERCE_THREATS.md` (home study) | https://github.com/TeamStarWolf/TeamStarWolf/blob/main/case-studies/ECOMMERCE_THREATS.md | 2026-11-12 | Confirmed; Reported (the September founding month) |
| 92 | TeamStarWolf library, `case-studies/` tree (homes for 2006 events: THREAT_ACTORS_CHINA.md, HACKER_AND_THE_STATE_CASES.md, CYBERCRIME_FOUR_BOOKS.md, ECOMMERCE_THREATS.md, CHRONICLE_2005.md) | https://github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies | 2026-11-12, 2026-11-13 | Confirmed |
| 93 | TeamStarWolf library, `data/attack/` (groups, software and campaigns) | https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack | 2026-11-12, 2026-11-13 | Demonstrated |
| 94 | TeamStarWolf library, `mitre/` page tree (technique, group, software, CAPEC, D3FEND and mitigation pages) | https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre | 2026-11-12, 2026-11-13 | Demonstrated; Inferred (the bindings) |
| 95 | TeamStarWolf library, `mitre/capec/CAPEC-100.md` | https://github.com/TeamStarWolf/TeamStarWolf/blob/main/mitre/capec/CAPEC-100.md | 2026-11-12 | Inferred (the pairing) |
| 96 | TeamStarWolf library, `data/attack/technique_to_d3fend.jsonl` | https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_to_d3fend.jsonl | 2026-11-12, 2026-11-13 | Confirmed; Demonstrated |
| 97 | TeamStarWolf library, `data/weaknesses/cwe.jsonl` and `data/weaknesses/capec.jsonl` | https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/weaknesses/cwe.jsonl | 2026-11-12, 2026-11-13 | Confirmed; Inferred (the CWE classes) |
| 98 | TeamStarWolf library, `data/attack/technique_profiles.jsonl` (names and tactics) | https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_profiles.jsonl | 2026-11-13 | Demonstrated |
| 99 | TeamStarWolf library, `navigator/library-layers/chronicle-2016.json` (layer format and scoring scale) | https://github.com/TeamStarWolf/TeamStarWolf/blob/main/navigator/library-layers/chronicle-2016.json | 2026-11-13 | Demonstrated |
| 100 | US-CERT, Microsoft Word Vulnerability, 19 May 2006 (CISA archive) | https://www.cisa.gov/news-events/alerts/2006/05/19/microsoft-word-vulnerability | 2026-11-13 | Confirmed |
| 101 | NVD API, CVE-2006-3590 | https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2006-3590 | 2026-11-13 | Confirmed |

*© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation.*

*This project is not affiliated with or endorsed by MITRE.*

*© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/*

*© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/*

*© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/*

*The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.*

## Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference, Privacy Engineering, GRC and Compliance, Vulnerability Management, Incident Response, Vulnerability Root Causes, ICS/OT Security, ICS ATT&CK Atlas
- Home studies: E-Commerce Threats; Four Books on Cybercrime; China-attributed actors; The Hacker and the State; APT41; Ransomware ecosystem; Healthcare threat watchlist; Stuxnet; ICS attacks and advisories; Log4Shell; SolarWinds SUNBURST; npm supply-chain attacks; Hugging Face supply chain; The Year 2004 in Intrusions (APT1's first domains and WEBC2 before 2006); The Year 2005 in Intrusions (the ChoicePoint and CardSystems breaches, Ancheta's arrest, the Windows Metafile disclosure and the Athens wiretaps' discovery)
- Series: 1993, 1994, 1995, 1996, 1997, 1998, 1999, 2000, 2001, 2002, 2003, 2004, 2005, 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024, 2025, 2026
- Techniques: T1203 Exploitation for Client Execution, T1189 Drive-by Compromise, T1566.001 Spearphishing Attachment, T1204.002 Malicious File, T1210 Exploitation of Remote Services, T1071 Application Layer Protocol, T1584.005 Botnet, T1498 Network Denial of Service, T1485 Data Destruction, T1685 Disable or Modify Tools, T1021.002 SMB/Windows Admin Shares, T1040 Network Sniffing, T1074 Data Staged, T1583.001 Domains, T1568.001 Fast Flux DNS, T1056.001 Keylogging, T1560 Archive Collected Data, T1105 Ingress Tool Transfer, T1059.003 Windows Command Shell, T1574.001 DLL; object techniques T1566.002, T1036.005, T1560.001
- CAPEC: CAPEC-8, CAPEC-63, CAPEC-66, CAPEC-100, CAPEC-125, CAPEC-158, CAPEC-163, CAPEC-242, CAPEC-561, CAPEC-568, CAPEC-578
- Groups and software: APT1 G0006 and WEBC2 S0109; menuPass G0045; PoisonIvy S0012
- Navigator layers, including this study's layer, chronicle-2006.json